

AGOS (Agent Governance OS) 企业级 AI 代理治理操作系统架构构想

作者：别业辉 日期：2026-09-20 ⚠ 说明：本文为架构构想 / 设计白皮书，暂无代码实现，属于概念设计文档，欢迎行业参考借鉴，转载、商业参考实现请注明来源

适合直接导出 PDF：复制全部内容到 Word / Typora / WPS，页面设置 A4，导出 PDF，即可上传创客 IP 平台。排版提示：关闭代码换行，图表部分用文字框图替代（原 mermaid 文本框图保留，PDF 可正常渲染；如果平台不渲染框图，可以删掉框图图片标记，保留文字架构）

AGOS (Agent Governance OS)：企业级 AI 代理治理操作系统架构构想

摘要

随着具备执行能力的 AI 智能体 (Agent) 快速普及，AI 代理不再仅做对话问答，而是深度参与企业即时通讯、OA、ERP、CRM 业务操作，还可通过 MCP 协议调用外部生活服务。但当前企业普遍存在代理身份混乱、权限失控、通讯无标识、操作缺少分级审批、信息无法溯源、审计追责困难等治理空白。企业普遍现状：POC 试点效果很好，但规模化生产环境不敢落地。

AGOS Agent Governance OS，即智能代理治理操作系统，是一套叠加在现有企业系统之上的治理架构。不替代现有 IM、业务系统、大模型平台，而是作为一层“安全管控罩”，对所有 AI 代理行为统一做身份、授权、操作分级、转人工、信息溯源、全链路审计。实现：消息可识别、操作可管控、来源可溯源、事件可审计、风险可熔断。

核心理念：产品功能让用户愿意用，治理功能让企业敢用。

关键词：AI 智能体；Agent 治理；MCP；PAP-PDP-PEP；操作分级 L0-L4；二次鉴权；全链路审计；数字员工

一、问题陈述：企业 AI 代理通讯与业务操作的治理空白

1.1 时代背景：AI 代理从“对话”走向“执行”

2026 年，AI 代理开始以员工账号身份参与企业通讯，接入 OA、ERP、CRM 执行业务查询、创建、修改、流程流转，通过 MCP 调用打车、外卖、搜索、媒体生成等外部服务。

- Gartner 预测：2026 年底，40% 企业应用嵌入具备任务执行能力的 AI 智能体。

- IDC 预测：2026-2027 国内企业活跃智能体数量同比增速超 200%。

智能体数量爆发，但配套治理能力严重滞后。

1.2 核心矛盾：想用，但不敢用、用不好

企业希望 AI 代理实现降本提效，但缺少对代理身份、权限、操作、溯源、审计完整能力：

1. **不敢放权**：代理仅能执行只读查询，无法进入核心业务流程；
2. **不敢接入**：不能访问敏感数据、关键业务系统；
3. **不敢规模化**：少量试点可行，大规模部署风险不可控；
4. **出事查不清**：缺少全链路审计，责任无法定位、操作无法回滚、难以应对监管检查。

1.3 五大具体治理空白

1. **代理身份与权限空白** 69% 企业存在多 Agent 共享凭证，安全事件发生率比使用独立身份的企业高 55%。代理没有独立身份，无法回答：它是谁、代表谁、能访问什么，越权与数据泄露无法源头管控。
2. **通讯治理空白** AI 代理以员工名义在私聊、群聊发送消息；缺少强制真人 / AI 标识、缺少转人工兜底、缺少消息审计；接收方无法分辨对话对象是人还是 AI；问题无法无缝交还人工；消息无法追溯授权人与知识来源。
3. **业务操作治理空白** 代理调用 OA、ERP、工单、支付系统，操作无分级、无审批、无回滚、无沙箱；只读查询与高危写入共用一套权限；误下单、越权修改风险扩大。
4. **信息溯源空白** AI 输出来源混杂网络搜索、企业知识库、业务 API、模型内置知识；无法区分来源，无法标记信息可信度、文档版本；合规业务场景中，不可溯源等于不可用。
5. **审计与追责空白** 81% 企业反馈人工审计 AI 代理消耗的时间已经超过 Agent 节省工时。传统软件具备完整日志链路；Agent 仅有对话记录。无法回答：代理做了什么、调用哪些工具、访问哪些数据、何时触发人工介入、故障是否支持回滚，无法满足 SOC2、国内监管内审要求。

1.4 现有方案的局限性

表格

方案类型	能力	关键短板
企业 IM（飞书 / 钉钉 / 企微）	安全消息通讯	AI 治理能力弱，绑定自有生态，跨系统治理缺失
RPA 自动化工具	业务流程执行	缺少 Agent 独立身份、通讯治理、统一审计闭环
开源 AI/MCP 网关	身份、协议网关	缺少 IM 通讯治理、转人工、信息溯源完整闭环
海外商业 Agent 网关	集中管控	偏向通用框架，缺少企业 IM 人机协同场景，生态绑定
大厂 Agent 平台	Agent 构建、工具调用	强绑定厂商生态；跨平台、私有化异构系统整合缺失
传统 IAM/SOC	身份访问、安全审计	为“人”设计，不懂 Agent 动态任务上下文、转人工、MCP 外部调用

1.5 监管与市场趋势

国内《智能体规范应用与创新发展实施意见》明确要求智能体落实权限管理、行为管控、分类分级治理。 Gartner 预判，2027 年底超 40% Agentic AI 项目会因为风险不可控、成本失控被终止。

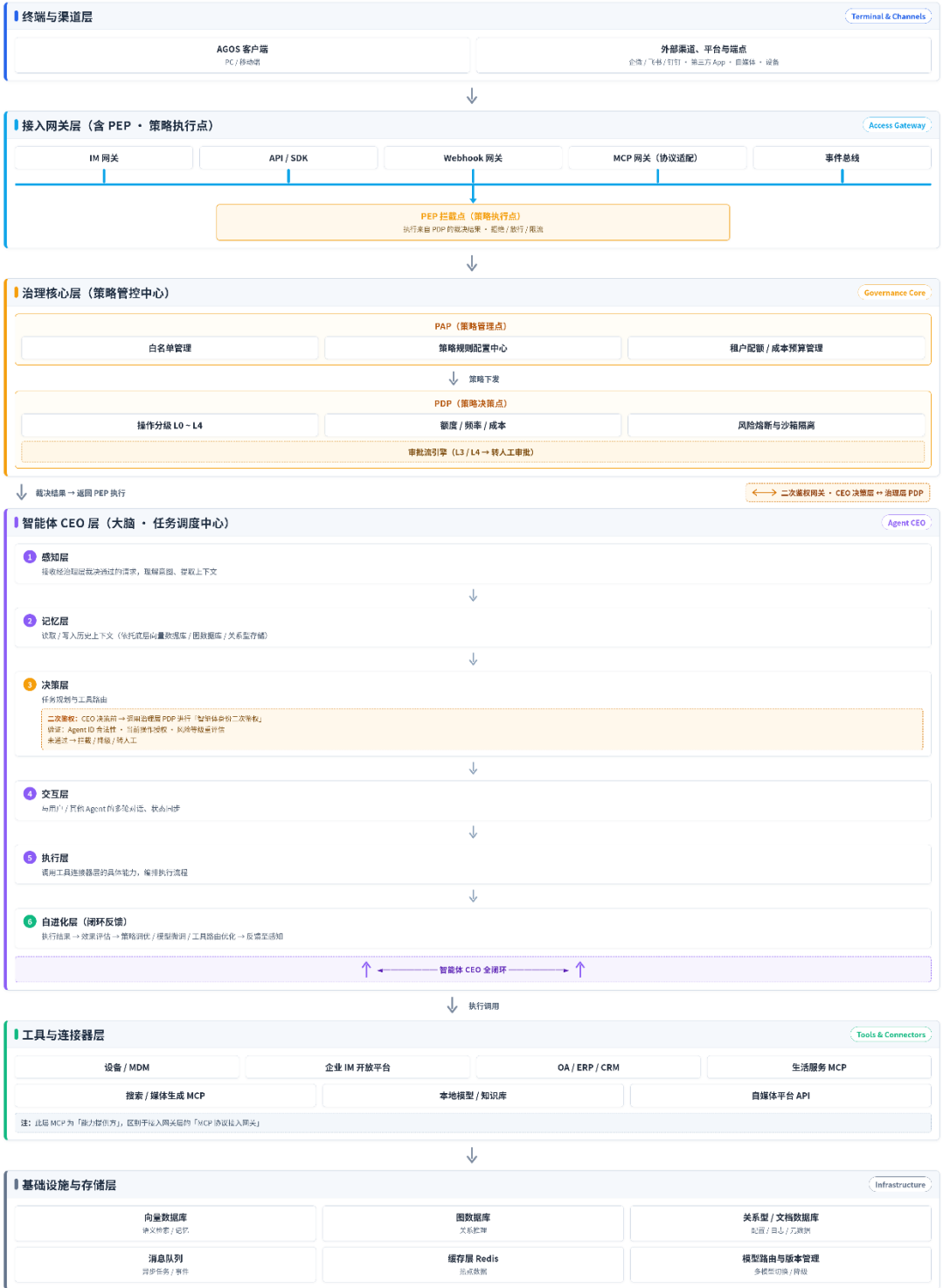
Agent 治理已经从“最佳实践”转变为**规模化落地的合规刚需**。

1.6 结论：需要 AGOS 这一类治理操作系统

企业需要的不是另一个大模型、不是 IM、不是 RPA 工具；而是一套叠加在现有系统之上的治理操作系统：

- 1. AI 代理具备独立身份、最小授权，受控接入通讯、业务系统；
- 2. 每一条消息、查询、业务操作实现：可身份、可授权、可分级、可溯源、可审计、可回滚；
- 3. AI 无法处理任务可无缝转人工，明确身份切换通知；
- 4. 解决企业不敢大规模上线 AI 代理的现实痛点。

二、AGOS 整体分层架构



整体分层自上而下：

1. 终端与渠道层
2. 接入网关层（PEP 策略执行点）
3. 治理核心层（策略管控中心 PAP+PDP）
4. 智能体 CEO 层（任务调度大脑）

5. 工具与连接器层

6. 基础设施存储层

三大贯穿全部层级横切层：

- 信息溯源与审计层
- 安全能力层
- 可观测性层

2.1 分层简要说明

① 终端与渠道层

包含 AGOS PC / 移动端客户端；外部渠道：企微、飞书、钉钉、第三方 App、自媒体、设备端点。

② 接入网关层（PEP 策略执行点）

网关层是策略执行拦截点，包含 IM 网关、API/SDK 网关、Webhook 网关、MCP 协议网关、事件总线。所有外部请求统一进入网关；**PEP 执行来自 PDP 策略裁决结果，执行放行、拒绝、限流、日志记录。**

③ 治理核心层（策略管控中心）

核心职责：回答 **能不能做**

1) **PAP 策略管理点（配置面）** 白名单管理、策略规则配置中心、租户配额与成本预算管理。管理员在这里配置全部安全策略。

2) **PDP 策略决策点（运行时裁决面）** 操作分级 L0-L4；额度 / 频率 / 成本控制；风险熔断、沙箱隔离；L3/L4 高危操作审批流引擎。接收请求上下文，输出裁决结果（放行 / 拒绝 / 审批 / 转人工）下发给 PEP 执行。

关键机制：**智能体 CEO 决策之后执行工具调用前，需要再次调用 PDP 做二次鉴权。**防止大模型推理阶段构造绕过第一层网关的高危调用。

④ 智能体 CEO 层（任务调度大脑）

核心职责：回答 **怎么做** 重要：架构支持外置 CEO 模式，CEO 可以不在 AGOS 内部运行，外部 Dify / 自研 Agent 也可以接入 AGOS 治理。

六大子模块：

1. **感知层**：接收经过网关裁决的请求，识别用户意图、提取上下文
2. **记忆层**：会话上下文、任务状态，底层依托向量、图、关系数据库

3. **决策层**：任务拆解、工具规划路由；**执行前调用 PDP 二次鉴权**；校验 Agent 身份、操作授权、风险重评估；不通过则拦截、降级、转人工
4. **交互层**：多轮对话，用户与其他 Agent 状态同步
5. **执行层**：编排流程，调用下层工具连接器
6. **自进化层**：基于执行结果反馈优化记忆、提示词、工具路由；**技术隔离禁止修改治理策略**

⑤ 工具与连接器层

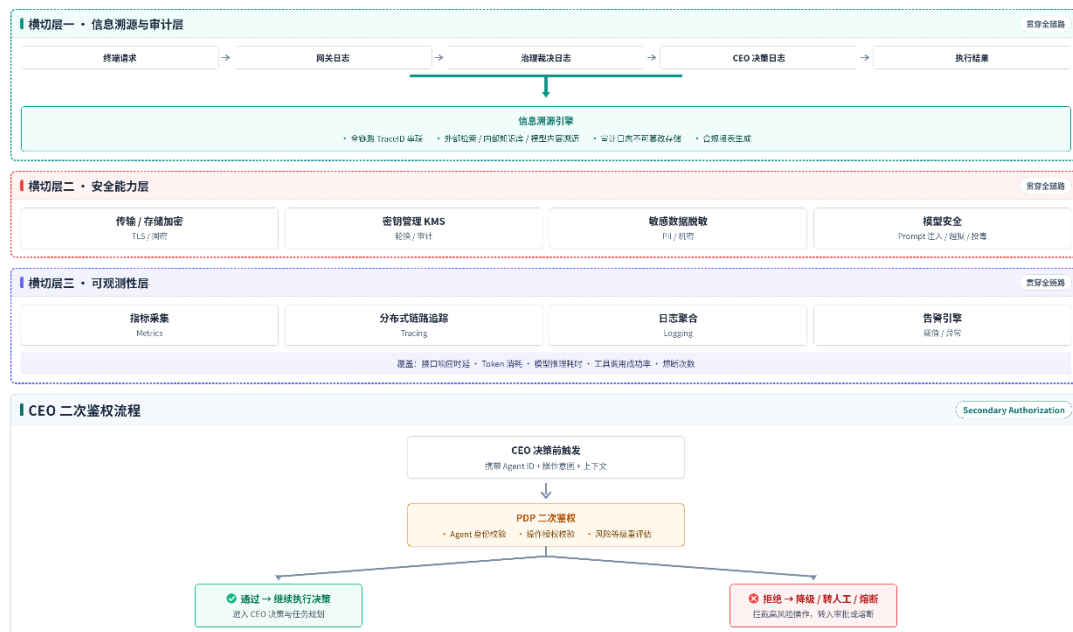
对接各类企业与外部能力：企业 IM 开放平台；OA/ERP/CRM 工单；MCP 生活服务；搜索、多媒体生成 MCP；本地知识库 / 私有化模型；MDM 设备控制；自媒体平台 API。

区分：接入网关层 MCP 为**协议接入适配**；工具连接器层 MCP 是实际能力提供方。

⑥ 基础设施与存储层

向量数据库、图数据库、关系 / 文档数据库；消息队列、缓存 Redis；模型路由与版本管理。

2.2 三大横切层（贯穿全部层级）



1. **信息溯源与审计层** 全局唯一 TraceID 串联完整链路：终端请求-网关日志-治理裁决-CEO 决策-工具执行结果。溯源引擎区分信息来源（知识库 / 搜索 / 模型内置知识）；审计日志支持不可篡改存储；自动生成合规报表。
2. **安全能力层** 传输与存储加密（TLS / 国密）、KMS 密钥管理；PII 敏感数据双

向脱敏；模型安全防护（Prompt 注入、越狱、投毒检测）。

3. **可观测性层** Metrics 指标采集、分布式链路追踪、统一日志聚合、告警引擎。
监控指标包含接口时延、Token 消耗、模型耗时、工具调用成功率、熔断触发次数。

2.3 核心职责边界：治理核心层 VS 智能体 CEO 层

表格

维度	治理核心层 (PAP/PDP)	智能体 CEO 层
定位	规则制定，准入管控	任务执行，智能调度
核心问题	能不能做	怎么做
决策依据	策略、权限、风险等级	L0-L4 意图理解、上下文、工具能力
输出结果	放行 / 拒绝 / 限流 / 转人工	工具调用链、回复内容、行动步骤

2.4 操作分级模型 L0-L4（AGOS 核心模型）

- **L0：只读自动放行：**查询类，无数据修改；
- **L1：生成建议人工确认：**Agent 输出方案，必须人工确认才生效；
- **L2：低风险自动执行：**低影响变更，可自动执行，完整留痕；
- **L3：高风险审批执行：**必须经过人工审批流程才允许执行；
- **L4：禁止 AI 代理执行：**高危操作，AI 完全禁止，只能真人操作。

三、关键业务能力总览

分为产品能力面向终端使用者；治理能力面向安全、IT 管理员。

通讯与消息

私聊、群聊、消息推送、多消息形态（文本、卡片、文件）、消息历史、离线消息。

账号与身份

个人账号、企业综合共享账号；智能体绑定、webhook 绑定；AI 不可篡改身份标识；转人工提示标识；代理发送消息标注“由 XX 智能体代理”。

智能体管理

Agent 注册分配唯一 Agent ID；多智能体分流路由；响应规则配置；智能体状态监控；用户手动切换智能体。

转人工闭环

一键人工接管、自动转人工；完整上下文继承；明确身份切换通知；人工排队分配。

治理安全核心能力

三层白名单（Agent、IM/Webhook、MCP 工具）；独立 Agent ID 杜绝凭证共享；委托授权生命周期；PAP/PDP/PEP 完整策略框架；L0-L4 操作分级；审批流转人工；额度频率成本管控；风险熔断沙箱；二次鉴权。

审计溯源

全链路 TraceID 审计日志；信息来源溯源引擎；日志导出，支持对接外部 SIEM/SOC。

接入网关

IM 网关、API SDK、Webhook 网关、MCP 协议网关、内部事件总线。

工具连接器

业务系统对接、MCP 各类外部能力、私有化知识库、多模型管理。

客户端与管理后台

PC、移动端；会话管理；审批通知；组织架构；策略配置仪表盘；审计检索导出。

可观测性

系统监控、异常告警、分布式链路追踪、合规指标采集。

核心理念：产品能力让用户愿意用，治理能力让企业敢用。两者合并构成 AGOS 完整形态。

四、面向开源、大企业与政务场景的演进优化方向（构想扩展）

本部分为架构补充思考，如果未来作为开源项目落地，需要补齐现实工程与行业短板：

1. **信创合规增强**：等保 2.0、三员分立；WORM 防篡改审计日志；国密全链路；数据密级与 L0-L4 操作联动；委托权限自动回收，防止人员离职遗留僵尸权限。
2. **架构可插拔**：内核 PAP/PDP/PEP 可以独立作为服务调用；智能体 CEO 支持外置模式，不强制内置 Agent 运行；输出 CEF/CEE 标准日志对接企业现有 SOC；支持 GitOps 策略版本管理。
3. **政企特有场景**：多级组织策略继承与策略锁；内外网 / 涉密网网域隔离策略；输出内容水印与溯源；公文场景约束 Agent 仅输出草稿不能直接归档正式公

文。

4. **安全加固**：增加输出侧 PEP 校验（防止输入合法、输出泄露敏感信息）；沙箱分为测试沙箱、高危预执行沙箱；故障降级策略（治理故障时，可配置全部阻断，或者仅放行 L0 只读）；MCP 工具细粒度权限管控、第三方 MCP 供应链安全扫描。
5. **取证运维增强**：TraceID 一键导出数字签名证据包；风险事件根因分析。

五、项目定位与现实路径（重要）

⚠️ **重要声明**：AGOS 目前为**公开架构构想、设计白皮书**，**暂无任何代码实现，不是可用软件**。

1. 定位：叠加式治理层，**不替代现有 IM、ERP、IAM、大模型平台**；
2. 落地路径建议：在缺少开发资源条件下，优先传播架构思想，鼓励现有开源项目、商业厂商参考借鉴；可以对外提供架构咨询，不需要从零开发整套软件；
3. 预期：不一定会诞生一个完全原样实现的 AGOS 软件，更大可能是本架构中多个核心模型（L0-L4 分级、网关 + 决策层二次鉴权、通讯-操作-溯源-审计闭环）被行业碎片化吸收。只要思想被采纳，构想就产生价值。

版权与引用声明

AGOS (Agent Governance OS) 企业级 AI 代理治理操作系统架构构想 作者：别业辉
创作日期：2026-09-20

1. 本文档全部内容为公开架构构想，欢迎个人、开源项目、商业厂商参考借鉴实现；
2. 转载、方案引用、产品参考实现，请注明来源“别业辉，AGOS Agent Governance OS 架构构想”；
3. 禁止去除原作者信息，将本文直接宣称作为原创方案对外发布；
4. 本构想无任何担保，仅供行业技术参考，不构成产品交付承诺。